

Contrôle d'Exécution, AppLocker et Sécurisation PowerShell

Objectifs :

- Comprendre l'obsolescence des approches de sécurité basées sur les signatures (Blacklisting).
- Maîtriser le concept de "Liste Blanche" (Whitelisting) et la mécanique interne d'AppLocker.
- Identifier les failles de configuration classiques (Bypass AppLocker via les dossiers permissifs).
- Sécuriser l'interpréteur PowerShell face aux attaques "Living off the Land" (LotL).
- Comprendre l'intégration native entre AppLocker et le Constrained Language Mode (CLM).

1. Le changement de paradigme : La fin de l'Antivirus traditionnel

La sécurité des postes de travail et des serveurs Windows a reposé sur un modèle de **Liste Noire (Blacklisting)**. Le système d'exploitation autorise l'exécution de n'importe quel fichier, à moins qu'un agent de sécurité (l'Antivirus) ne le reconnaisse comme malveillant et ne l'intercepte.

1.1 L'échec du Blacklisting face aux attaquants modernes

Le modèle de la liste noire est aujourd'hui considéré comme insuffisant par l'ANSSI pour trois raisons majeures :

- **Le Polymorphisme et le FUD (Fully Undetectable)** : Les attaquants automatisent la recompilation ou l'offuscation de leurs malwares (Ransomwares). Chaque victime reçoit un exécutable avec une empreinte cryptographique (Hash) unique. L'antivirus basé sur des signatures connues est totalement aveugle face à un fichier qui vient d'être compilé il y a 3 minutes.
- **Le Fileless Malware** : Les attaques modernes ne déposent plus de fichier `.exe` sur le disque dur. Le code malveillant est injecté directement dans la mémoire vive (RAM) d'un processus légitime existant (ex: `explorer.exe`). L'antivirus classique, qui scanne le disque, ne voit rien.
- **Le "Living off the Land" (LotL)** : Plutôt que d'apporter leurs propres outils de piratage,

les attaquants "vivent sur le pays". Ils utilisent les binaires légitimes natifs de Windows (les LOLBins) pour exécuter leurs actions.

- Exemple : Un attaquant utilise `certutil.exe` (un outil Microsoft légitime de gestion des certificats) pour télécharger un malware depuis Internet. L'Antivirus ne bloquera jamais `certutil.exe` car il est signé numériquement par Microsoft Corporation.

1.2 La solution Architecturale : Le Contrôle d'Exécution (Whitelisting)

Pour contrer ces menaces, les référentiels de sécurité imposent d'inverser le modèle : le **Zero Trust d'exécution. Rien ne s'exécute par défaut**. Seuls les exécutables, scripts, installeurs et bibliothèques (DLL) qui ont été explicitement autorisés par l'administrateur système ont le droit de démarrer. Si un Ransomware inconnu tente de s'exécuter, même s'il contourne l'antivirus, le noyau Windows (Kernel) refusera de lancer le processus car l'application n'est pas sur la "Liste Blanche".

2. AppLocker : Déploiement et Mécanique Interne

Introduit avec Windows 7 et Windows Server 2008 R2, **AppLocker** est le moteur natif de Microsoft permettant de créer des règles de restriction logicielles, distribuées via les Stratégies de Groupe (GPO). Sous le capot, il s'appuie sur le service d'Identité de l'Application (`AppIDSvc`).

2.1 Les trois types de règles (Conditions)

Lorsqu'un architecte crée une règle AppLocker, il doit choisir comment identifier le programme autorisé. Il existe trois méthodes :

1. La condition de Hachage (Hash) :

- Principe : Calcule l'empreinte cryptographique (SHA-256) du fichier `.exe` et l'autorise.
- Avantage : Extrêmement granulaire et sécurisé. Même si le malware est renommé `winword.exe`, son hash sera différent, il sera bloqué.

2. La condition de Chemin (Path) - (Danger Élevé) :

- Principe : Autorise tout ce qui s'exécute depuis un dossier précis (ex: `C:\Program Files\MonApplication\*`).
- Le risque de sécurité (Bypass) : Les administrateurs créent souvent des règles autorisant `C:\*` ou des dossiers utilisateurs. Si un attaquant trouve un dossier couvert par une règle "Chemin" mais sur lequel un utilisateur standard possède des droits d'écriture (NTFS "Modifier"), il lui suffit d'y déposer son malware pour

qu'AppLocker l'autorise aveuglément.

3. La condition d'Éditeur (Publisher) - La méthode recommandée par l'ANSSI :

- Principe : Autorise l'exécution en se basant sur le **Certificat de Signature Numérique** encapsulé dans l'exécutable.
- Exemple : "Autoriser tous les exécutables dont le certificat est signé par O=Microsoft Corporation, O=Google LLC ou O=MonEntreprise".
- Avantage : Résiste aux mises à jour. Quand Google Chrome se met à jour, le binaire change, mais il est toujours signé par le certificat de Google. La règle AppLocker reste valide sans aucune intervention de l'administrateur.

2.2 Les Règles par Défaut et la Chasse aux Bypass

Pour éviter aux administrateurs de "bricker" leur OS (bloquer le démarrage de Windows lui-même), AppLocker propose de générer des "Règles par défaut". Celles-ci autorisent globalement l'exécution de tout ce qui se trouve dans `C:\Windows\*` et `C:\Program Files\*`.

Le problème de sécurité des règles par défaut : Le postulat est que seul un Administrateur local peut écrire dans ces dossiers. C'est faux. Par défaut, Windows possède des sous-dossiers dans `C:\Windows` accessibles en écriture aux utilisateurs standards (et donc aux malwares) :

- `C:\Windows\Temp\`
- `C:\Windows\Tasks\`
- `C:\Windows\System32\spool\drivers\color\`
- `C:\Windows\Tracing\`

Remédiation ANSSI : Lors du déploiement d'AppLocker, l'architecte doit obligatoirement identifier ces dossiers "permissifs" et créer des règles AppLocker explicites d'interdiction (Deny) ciblées sur ces chemins, ou utiliser exclusivement des règles d'Éditeur.

3. La Sécurisation de PowerShell (La faille logique)

PowerShell n'est pas qu'un outil de script, c'est un accès direct au framework .NET et aux API Windows de très bas niveau (C#). C'est aujourd'hui l'arme absolue des attaquants. Le célèbre outil **Mimikatz** peut être exécuté entièrement en mémoire via le script `Invoke-Mimikatz.ps1`, contournant ainsi la détection des malwares sur le disque dur.

3.1 Le Mythe de l'Execution Policy (Ceinture de sécurité en papier)

La première erreur est de croire que la GPO `Set-ExecutionPolicy Restricted` est une mesure de sécurité.

- Cette fonction a été créée par Microsoft uniquement pour éviter qu'un administrateur

ou un utilisateur ne double-clique sur un script PowerShell par erreur.

- **Le Bypass** : L'Execution Policy n'est pas une barrière de sécurité. Un attaquant (même sans droits administrateur) peut la désactiver instantanément de dizaines de façons différentes, la plus connue étant : `powershell.exe -ExecutionPolicy Bypass -File malware.ps1` L'ANSSI exige de ne pas s'appuyer sur l'Execution Policy pour contrer les cyberattaques.

3.2 La véritable arme défensive : Constrained Language Mode (CLM)

Microsoft a introduit un mécanisme de sécurité fondamental dans PowerShell : les modes de langage.

- **Full Language Mode** : Comportement par défaut. Le script peut manipuler la mémoire du système, invoquer l'API Windows (Win32), et utiliser la "Reflection" .NET. C'est ce dont ont besoin les malwares complexes.
- **Constrained Language Mode (CLM)** : Dans ce mode, PowerShell est "castré". L'utilisateur peut toujours utiliser les commandes d'administration classiques (`Get-Process`, `Get-ADUser`, ping), mais **toutes les invocations d'API bas niveau, la création de types C# dynamiques, et l'accès à la cryptographie brute sont bloqués**.
- **Résultat** : Si un attaquant tente de lancer `Invoke-Mimikatz` ou un script de Ransomware PowerShell en mode CLM, le script crashe immédiatement en retournant des dizaines d'erreurs d'accès refusé.

3.3 L'intégration symbiotique entre AppLocker et CLM

Comment activer le mode CLM pour les utilisateurs standards ? **C'est la magie d'AppLocker**. Dès lors qu'AppLocker est activé sur un système et que la collection de règles "Scripts" (`.ps1`, `.vbs`, `.bat`) est configurée (même avec les règles par défaut), **PowerShell détecte la présence d'AppLocker et bascule automatiquement et silencieusement tous les utilisateurs non-administrateurs en Constrained Language Mode (CLM)**. Si le script est signé par l'entreprise (Autorisé par AppLocker), il s'exécutera en Full Language. S'il n'est pas signé ou s'il est tapé à la main, il s'exécute en CLM.

3.4 AMSI (Antimalware Scan Interface)

Introduit sous Windows 10 et Windows Server 2016+, l'AMSI est l'ultime filet de sécurité. Avant l'AMSI, un attaquant pouvait obfusquer son script PowerShell (remplacer les lettres par des variables complexes) pour le rendre illisible. Aujourd'hui, avant que PowerShell n'exécute réellement le code en mémoire (au moment exact où il est déchiffré), il l'envoie en clair à l'AMSI. L'AMSI agit comme un pont : il transmet le script en clair à l'Antivirus (Defender ou tiers). Si l'Antivirus reconnaît une signature malveillante (ex: le mot clé Mimikatz), l'exécution est stoppée

net.

4. Stratégie de Déploiement en Production (Le Mode Audit)

Activer AppLocker en mode "Bloquer" directement sur un parc informatique est la garantie absolue de paralyser l'entreprise. Des dizaines de scripts de connexion, de macros métiers ou d'applicatifs internes non signés seront immédiatement détruits.

4.1 La phase d'Auditer Uniquement (Audit Only)

1. **Déploiement initial** : La GPO AppLocker est configurée en **Mode Audit**. Dans ce mode, AppLocker ne bloque strictement rien. Cependant, chaque fois qu'un programme ou un script aurait dû être bloqué selon les règles, AppLocker génère un journal d'événement Windows (Event ID 8003 ou 8004) dans l'Observateur d'événements (AppLocker > EXE and DLL / MSI and Script).
2. **Centralisation (WEF)** : Ces journaux d'audit sont collectés et envoyés vers un serveur central (Windows Event Forwarding) ou un SIEM (SOC).
3. **Analyse et Ajustement** : L'architecte analyse les journaux pendant plusieurs semaines. Il identifie les "Faux Positifs" (les applications légitimes qui auraient été bloquées) et crée des règles d'Éditeur ou de Hash pour les autoriser.
4. **Mise en Application (Enforce)** : Lorsque les journaux d'audit deviennent silencieux, cela signifie que la Liste Blanche est complète et adaptée à la réalité du parc. La GPO peut alors être basculée en mode "Appliquer les règles".